

CYBERSECURITY FUNDAMENTALS AND NETWORK SECURITY

Unit-01 CYBERSECURITY FUNDAMENTALS

Created by: Gayathri Gagana

Email Address: gayathri.g@techdefence.com



LJ University
University with a Difference



TechDefencelabs

CONTENT



- ❑ What is Cybersecurity?
- ❑ Information Security V/S Cybersecurity
- ❑ CIA Triad
- ❑ Types of Cyber Attacks
- ❑ Cyber Kill Chain
- ❑ Threat V/S Vulnerability V/S Risk
- ❑ Threat Actors
- ❑ Attack Surface

WHAT IS CYBERSECURITY?



Cybersecurity is the process of protecting networks, systems, applications and digital assets from unauthorized access, cyberattacks, malware and data breaches. It ensures the confidentiality, integrity and availability (CIA) of information while supporting secure and sustainable digital infrastructure.

- Protects sensitive data using encryption, authentication and access control.
- Secures networks and systems against malware, ransomware and cyber threats.
- Supports safe digital transformation through secure cloud and IT infrastructure.
- Reduces downtime, resource misuse and operational risks caused by attacks.
- Enhances the reliability and resilience of modern digital technologies.

SCOPE OF CYBERSECURITY



- It encompasses several specialized disciplines, including:
- **Network Security:** Protects internal networks from intruders using tools like firewalls and VPNs.
- **Cloud Security:** Secures data and digital infrastructure hosted on remote cloud platforms.
- **Endpoint Security:** Protects individual devices like laptops, smartphones, and Internet of Things (IoT) gadgets
- **Mobile Security:** It Protects Android and iOS Applications from Vulnerabilities and Threats to safeguard our digital hand-held.
- **Wireless Security:** Protects the Wireless Network Components and performing test against the Security Mechanisms and Protocols applied for Wireless networks.

WHY IS CYBERSECURITY IMPORTANT?



1. Ensures Operational Continuity:

- The Concept: Maintaining the availability of critical systems so daily life and work can function without interruption.
- Importance: If a Ransomware attack hits you or your school, operational continuity breaks down. Cybersecurity ensures that online portals stay online, allowing you to submit assignments on time, take midterms, and access digital libraries without missing deadlines.

2. Safeguards Financial Assets:

- The Concept: Preventing unauthorized financial transactions and mitigating the direct and indirect costs of a data security incident.
- Importance: Falling victim to a Phishing scam can wipe out your checking account or compromise your tuition payments. Cybersecurity measures protect your hard-earned money and prevent you from having to pay hundreds of dollars to data recovery specialists to retrieve locked files

WHY IS CYBERSECURITY IMPORTANT?



3. Protects Digital Reputation and Trust

- The Concept: Maintaining the integrity and confidentiality of your public-facing accounts and personal data to preserve trust with external entities.
- Importance: If a hacker uses Credential Stuffing to hijack your social media or LinkedIn, they can post scams under your name. Strong cybersecurity preserves your digital footprint so that future employers, internship coordinators, and academic boards see a professional profile, not a compromised account.

WHY IS CYBERSECURITY IMPORTANT?



4. Guarantees Data Confidentiality and Privacy

- **The Concept:** Restricting access to sensitive data to ensure only authorized individuals can view or modify it.
- **Importance:** You have a right to privacy regarding your grades, medical history, and personal messages. Cybersecurity protocols (like encryption and MFA) ensure that malicious actors—or even an Insider Threat like a rogue student worker—cannot snoop through your private university files or personal communications

INFORMATION SECURITY V/S CYBERSECURITY



- While cybersecurity and information security (InfoSec) are closely related and often used interchangeably, they are not the same thing.
- The easiest way to understand their relationship is through a hierarchy: Information Security is the overarching umbrella, and Cybersecurity is a massive, specialized section underneath it.

The Core Difference: Medium vs. Threat Landscape

- Information Security (InfoSec) InfoSec focuses on protecting data from unauthorized access, use, disclosure, disruption, modification, or destruction, regardless of the form the data takes.
- **The Scope:** Covers physical paper, printed files, intellectual property, spoken secrets, and digital data.
- **Example:** Your university's InfoSec policy dictates that professors must lock physical filing cabinets containing printed midterm exams, and that shredded tuition checks must be disposed of in secure bins.

INFORMATION SECURITY V/S CYBERSECURITY



- **Cybersecurity:** Cybersecurity specifically focuses on protecting data, networks, devices, and programs from digital attacks originating from the internet or electronic systems.
- **The Scope:** Limited strictly to "cyberspace" the interconnected digital realm.
- **Example:** The university's cybersecurity policy mandates the use of network firewalls to block external hackers from breaking into the servers where digital grades are stored.
- **Where They Overlap:** Securing Digital Assets
 - The relationship becomes highly active where physical information turns digital. When data is stored electronically, it falls under the jurisdiction of both disciplines simultaneously.

INFORMATION SECURITY V/S CYBERSECURITY



- **Data Governance:** InfoSec establishes the rules of who is allowed to see data (e.g., "Students cannot view other students' transcripts"). Cybersecurity builds the digital access controls to enforce that rule in the university portal.
- **Incident Response:** If a hacker breaches a server, the Cybersecurity team works to isolate the malware and kick the attacker out of the network. Simultaneously, the InfoSec team assesses what specific data was exposed, evaluates legal compliance, and manages how to report the breach.

CIA TRIAD



- The CIA Triad is a fundamental framework in information security used to protect data and maintain secure, reliable systems. It guides policies to ensure information remains confidential, accurate and accessible to authorized users.
- **Confidentiality** ensures that sensitive data is accessible only to authorized individuals or systems. Its purpose is to prevent unauthorized viewing, access or misuse of private information.
- **Integrity** ensures that data remains accurate, authentic and unaltered during storage or transmission. Any unauthorized modification or corruption compromises the reliability of data.
- **Availability** ensures that systems, networks and data are accessible to authorized users whenever needed. Disruptions can halt operations and cause major losses.

CIA TRIAD



Confidentiality

Ensuring information is accessible only to those authorized to have access.



Integrity

Maintaining the accuracy and completeness of data over its entire lifecycle.



Availability

Ensuring information and resources are accessible when required by authorized users.

CONFIDENTIALITY



- **Confidentiality:** Ensures that sensitive information is accessible only to those authorized to view it.
- **Risks to Confidentiality:**
- **Unauthorized Access:** Attackers exploit vulnerabilities to access protected data.
- **Weak Encryption:** Outdated or weak encryption can be easily broken, exposing sensitive information.
- **Insider Threats:** Employees or trusted users may leak or accidentally expose confidential data.

INTEGRITY



- **Integrity:** Protects data from being tampered with or corrupted by unauthorized parties.
- **Risks to Integrity:**
- **Data Tampering:** Attackers may intentionally alter or corrupt data for malicious purposes.
- **Malware & Ransomware:** Malicious software can modify, encrypt or destroy data, leading to loss and system disruption.

AVAILABILITY



- **Availability:** Ensures authorized users have reliable and uninterrupted access to systems and information when needed.
- **Risks to Availability**
- **DoS and DDoS Attacks:** Denial of Service (DoS) or Distributed Denial of Service (DDoS) attacks flood network resources with excessive traffic, making them unavailable to legitimate users.
- **Impact:** Such attacks can cause major service disruptions, downtime and financial losses for companies.

TYPES OF CYBER ATTACKS



- Cyber attacks use different techniques to compromise computer systems, networks, applications and digital assets. Each attack type exploits specific vulnerabilities and follows a distinct method to achieve unauthorized access, data theft, service disruption or system compromise.
- Common types of Cyber Attacks are:
 1. Malware
 2. Phishing
 3. Denial of Service (DoS) Attack
 4. Man-in-the-middle Attack (MITM)
 5. SQL Injection
 6. Social Engineering

MALWARE



- Malware refers to malicious software designed to damage, disrupt or gain unauthorized access to computer systems or take control of a system without the user's knowledge.
- Malware is installed through infected files, software downloads or email attachments.
- It can steal personal information, passwords or financial data.
- **Example:** A Trojan malware hidden inside a cracked software installer steals browser-stored passwords after execution.

TYPES OF MALWARE



1. VIRUS:

Virus refers to a program which damages computer systems and/or destroys or erases data files. A computer virus is a malicious program that self-replicates by copying itself to another program. In other words, the computer virus spreads by itself into other executable code or documents. The purpose of creating a computer virus is to infect vulnerable systems, gain admin control and steal user sensitive data. Hackers design computer viruses with malicious intent and prey on online users by tricking them.

TYPES OF MALWARE



2. WORM:

A worm is a destructive program that fills a computer system with self-replicating information, clogging the system so that its operations are slowed down or stopped.

3. RANSOMWARE:

Ransomware is a type of malicious software (malware) that encrypts a victim's data or locks them out of their own computer systems, rendering them inaccessible until a ransom payment is made. Cybercriminals typically demand payment in untraceable cryptocurrency.

TYPES OF MALWARE



4. TROJAN:

A Trojan Horse is malware that looks like legitimate software. Once installed, it allows attackers to access or control the system.

5. SPYWARE:

Spyware is malware that secretly monitors user activities. It collects sensitive information like passwords, browsing history and personal data.

PHISHING



- Phishing is a cyberattack where attackers use fake messages or websites to trick victims into giving away sensitive information. It works like “fishing,” using bait to lure targets into clicking harmful links or entering confidential data.
- Aims to steal sensitive information such as user credentials, credit card details, government identification numbers and personal data by impersonating trusted organizations or online services.
- Commonly delivered through fraudulent emails, messages or spoofed websites that closely resemble legitimate platforms but use deceptive or suspicious URLs to trick users.

TYPES OF PHISHING



1. EMAIL PHISING:

- Attackers send fake emails pretending to be trusted organizations to steal sensitive information.
- Often request login credentials, banking details or personal information. May include malicious links or infected attachments.

Example: An email claiming to be from a bank asks the user to verify account details through a fake website.

TYPES OF PHISHING



2. SPEAR PHISHING:

- A targeted phishing attack aimed at a specific individual or organization.
- Uses personal or professional information to appear legitimate. Messages are customized to increase credibility.

Example: An employee receives an email appearing to be from their manager requesting access to a confidential document.

TYPES OF PHISHING



3. WHALING:

- A phishing attack specifically targeting senior executives and decision-makers.
- Focuses on CEOs, CFOs, directors and other high-ranking officials. Often involves requests for sensitive data or financial transactions.

Example: A CFO receives an email impersonating the CEO requesting an urgent wire transfer.

TYPES OF PHISHING



4. SMISHING:

- Phishing conducted through SMS or text messages.
- Contains fraudulent links or fake alerts. Attempts to steal credentials, OTPs or financial information.

Example: A text message claiming a package delivery issue asks the user to click a malicious tracking link.

TYPES OF PHISHING



5. VISHING:

- Phishing performed through voice calls.
- Attackers impersonate banks, government agencies or technical support. Victims are persuaded to reveal confidential information.

Example: A caller pretending to be a bank representative asks for an OTP to "verify" an account.

TYPES OF PHISHING



6. CLONE PHISHING:

- Attackers copy a legitimate email and replace its links or attachments with malicious ones.
- The cloned email closely resembles the original message. Victims trust the email because it appears familiar.

Example: A previously received company invoice is resent with a malicious attachment disguised as an updated document.

DOS (DENIAL OF SERVICE)



Denial of Service (DoS) is a cyber-attack on an individual Computer or Website with the intent to deny services to intended users. Their purpose is to disrupt an organization's network operations by denying access to its users. Denial of service is typically accomplished by flooding the targeted machine or resource with surplus requests in an attempt to overload systems and prevent some or all legitimate requests from being fulfilled.

DoS attacks exploit various weaknesses in computer network technologies. They may target servers, network routers, or network communication links. They can cause computers and routers to crash and links to bog down.

DOS (DENIAL OF SERVICE)



- The most famous DoS technique is the Ping of Death. The Ping of Death attack works by generating and sending special network messages (specifically, ICMP packets of non-standard sizes) that cause problems for systems that receive them.
- Another variant of the DoS is the Smurf attack. This involves emails with automatic responses. If someone emails hundreds of email messages with a fake return email address to hundreds of people in an organization with an autoresponder on in their email, the initially sent messages can become thousands sent to the fake email address. If that fake email address belongs to someone, this can overwhelm that person's account. DoS attacks can cause the following problems:
 - Ineffective services
 - Inaccessible services
 - Interruption of network traffic
 - Connection interference

DOS (DENIAL OF SERVICE)



How Do DoS Attacks Work?

DoS attacks typically exploit vulnerabilities in a target's network or computer systems. Attackers can use a variety of methods to generate overwhelming traffic or requests, including:

- Flooding the target with a massive amount of data
- Sending repeated requests to a specific part of the system
- Exploiting software vulnerabilities to crash the system

DDOS (DISTRIBUTED DENIAL OF SERVICE)



- A DDoS attack uses multiple servers and Internet connections to flood the targeted resource. A DDoS attack is one of the most powerful weapons on the cyber platform. When you come to know about a website being brought down, it generally means it has become a victim of a DDoS attack. This means that the hackers have attacked your website or PC by imposing heavy traffic. Thus, crashing the website or computer due to overloading.
- DoS stands for Denial of Service. It is a type of attack on a service that disrupts its normal function and prevents other users from accessing it. The most common target for a DoS attack is an online service such as a website, though attacks can also be launched against networks, machines, or even a single program.

DOS V/S DDOS



DoS	DDoS
DoS Stands for Denial of service attack.	DDoS Stands for Distributed Denial of service attack.
In Dos attack single system targets the victim system.	In DDoS multiple systems attack the victim's system.
Victim's PC is loaded from the packet of data sent from a single location.	Victim PC is loaded from the packet of data sent from Multiple locations.
Dos attack is slower as compared to DDoS.	A DDoS attack is faster than Dos Attack.

DOS V/S DDOS



DOS	DDOS
Can be blocked easily as only one system is used.	It is difficult to block this attack as multiple devices are sending packets and attacking from multiple locations.
In DOS Attack only a single device is used with DOS Attack tools.	In a DDoS attack, The volume Bots are used to attack at the same time.
DOS Attacks are Easy to trace.	DDOS Attacks are Difficult to trace.
Types of DOS Attacks are: 1. Buffer overflow attacks 2. Ping of Death or ICMP flood 3. Teardrop Attack 4. Flooding Attack	Types of DDOS Attacks are: 1. Volumetric Attacks 2. Fragmentation Attacks 3. Application Layer Attacks 4. Protocol Attack.

MAN IN THE MIDDLE ATTACK



A man-in-the-middle (MITM) attack is a cyberattack in which a hacker steals sensitive information by eavesdropping on communications between two online targets such as a user and a web application.

After stealthily placing themselves in the middle of two-party communications, MITM attackers intercept sensitive data such as credit card numbers, account information and login credentials. Hackers then use that information to commit other cybercrimes such as making unauthorized purchases, hijacking financial accounts and identity theft.

MAN IN THE MIDDLE ATTACK



HOW MITM WROKS?

- Vulnerabilities across networks, web browsers, email accounts, user behaviours and security protocols are the starting points of MITM attacks. Cybercriminals exploit these weaknesses to insert themselves between users and trusted applications so they can control communications and intercept data in real time.
- Phishing attacks are one common means of entry for MITM attackers. By clicking on a malicious link in an email, a user can unknowingly launch a man-in-the browser attack. MITM attackers often rely on this tactic to infect a user's web browser with malware that enables them to make covert changes to web pages, manipulate transactions and spy on the user's activity.

MITM ATTACK TECHNIQUES



Attackers use a variety of techniques to intercept and decrypt data during MITM attacks. Common techniques include:

- **IP spoofing:** Internet Protocol (IP) addresses identify online entities such as websites, devices and email addresses. MITM attackers alter or 'spoof' their IP addresses so it appears a user is communicating with a genuine host when they are actually connected to a malicious source.
- **ARP spoofing or ARP cache poisoning:** The Address Resolution Protocol (ARP) connects an IP address with the correct Media Access Control (MAC) address on a local area network. By spoofing the ARP address, an attacker can route this connection to their own MAC address to extract information.

MITM ATTACK TECHNIQUES



- **DNS spoofing:** The Domain Name System (DNS) connects the domain names of websites to their assigned IP addresses. By changing a domain name in the DNS records, an MITM attacker can route users away from a legitimate site to a fraudulent website.
- **HTTPS spoofing:** Hypertext Transfer Protocol Secure (HTTPS) ensures secure communications by encrypting the data that travels back and forth between a user and a website. MITM attackers will secretly route users to a standard HTTP page without encryption so they can access unprotected data.

SQL INJECTION



- **Structured Query Language (SQL)** is the standard language used to query a database.
- An SQL injection (SQLi) is a type of attack in which cyber criminals attempt to exploit vulnerabilities in an application's code by inserting an SQL query into regular input or form fields, such as a username or password. The SQL statement is then passed to the application's underlying SQL database.
- It exploits poor input handling, allowing attackers to bypass authentication, view, modify, or delete sensitive database records, and even gain administrative control over the underlying server.

SOCIAL ENGINEERING



Social engineering attacks manipulate people into sharing information that they shouldn't share, downloading software that they shouldn't download, visiting websites they shouldn't visit, sending money to criminals or making other mistakes that compromise their personal or organizational security.

Social engineering attacks happen in one or more steps. A perpetrator first investigates the intended victim to gather necessary background information, such as potential points of entry and weak security protocols, needed to proceed with the attack. Then, the attacker moves to gain the victim's trust and provide stimuli for subsequent actions that break security practices, such as revealing sensitive information or granting access to critical resources.

UNIFIED CYBER KILL CHAIN



In 2017, Paul Pols introduced the Unified Cyber Kill Chain to augment and expand upon the Cyber Kill Chain. The Unified Kill Chain incorporates elements from both the Lockheed Martin-Cyber Kill Chain and the MITRE ATT&CK framework. It distills the attack process into three high-level steps:

- Initial Foothold
- Network Propagation
- Action on Objectives.
- Such three steps make the attack process easier to understand, even for non-technical staff. Each of these tactics is then elaborated in detail with specific techniques.
- The Unified Kill Chain provides a robust foundation for strategically realigning defensive capabilities and cybersecurity investments within organizations, covering prevention, detection, response, and threat intelligence

UNIFIED CYBER KILL CHAIN



The Unified Kill Chain



1	Reconnaissance	Researching, identifying and selecting targets using active or passive reconnaissance.
2	Weaponization	Preparatory activities aimed at setting up the infrastructure required for the attack.
3	Delivery	Techniques resulting in the transmission of a weaponized object to the targeted environment.
4	Social Engineering	Techniques aimed at the manipulation of people to perform unsafe actions.
5	Exploitation	Techniques to exploit vulnerabilities in systems that may, amongst others, result in code execution.
6	Persistence	Any access, action or change to a system that gives an attacker persistent presence on the system.
7	Defense Evasion	Techniques an attacker may specifically use for evading detection or avoiding other defenses.
8	Command & Control	Techniques that allow attackers to communicate with controlled systems within a target network.
9	Pivoting	Tunneling traffic through a controlled system to other systems that are not directly accessible.
10	Discovery	Techniques that allow an attacker to gain knowledge about a system and its network environment.
11	Privilege Escalation	The result of techniques that provide an attacker with higher permissions on a system or network.
12	Execution	Techniques that result in execution of attacker-controlled code on a local or remote system.
13	Credential Access	Techniques resulting in the access of, or control over, system, service or domain credentials.
14	Lateral Movement	Techniques that enable an adversary to horizontally access and control other remote systems.
15	Collection	Techniques used to identify and gather data from a target network prior to exfiltration.
16	Exfiltration	Techniques that result or aid in an attacker removing data from a target network.
17	Impact	Techniques aimed at manipulating, interrupting or destroying the target system or data.
18	Objectives	Socio-technical objectives of an attack that are intended to achieve a strategic goal.

CYBER KILL CHAIN



Cyber Kill Chain:

- The Cyber Kill Chain was developed by Lockheed Martin, an American aerospace and security company, and is also referred to as the Cyber Attack Lifecycle.
- This framework, one of the earliest and best-known, takes a step-by-step approach to identify and interrupt adversarial activity.
- Drawing on a military concept, it breaks down cyberattacks into stages of the cyber kill chain with the aim of disrupting one kill chain step at a time.
- This allows cyber defenders to identify the current stage of an attack and deploy countermeasures accordingly.

CYBER KILL CHAIN



Kill Chain: The 7 Stages of a Cyber Attack

1. Reconnaissance

Scanning the environment or harvesting information from social media.



3. Delivery

Transmission of weapon/malware to target (e.g. via email, USB, website).



2. Weaponization

Pairing malicious code with an exploit to create a weapon (piece of malware).



4. Exploitation

Once delivered, the weapons/malware code is triggered upon an action. This in turn exploits the vulnerability.



5. Installation

The weapon installs malware on the system.



6. Command and Control

A command channel for remote manipulation of the victim.



7. Action on objectives

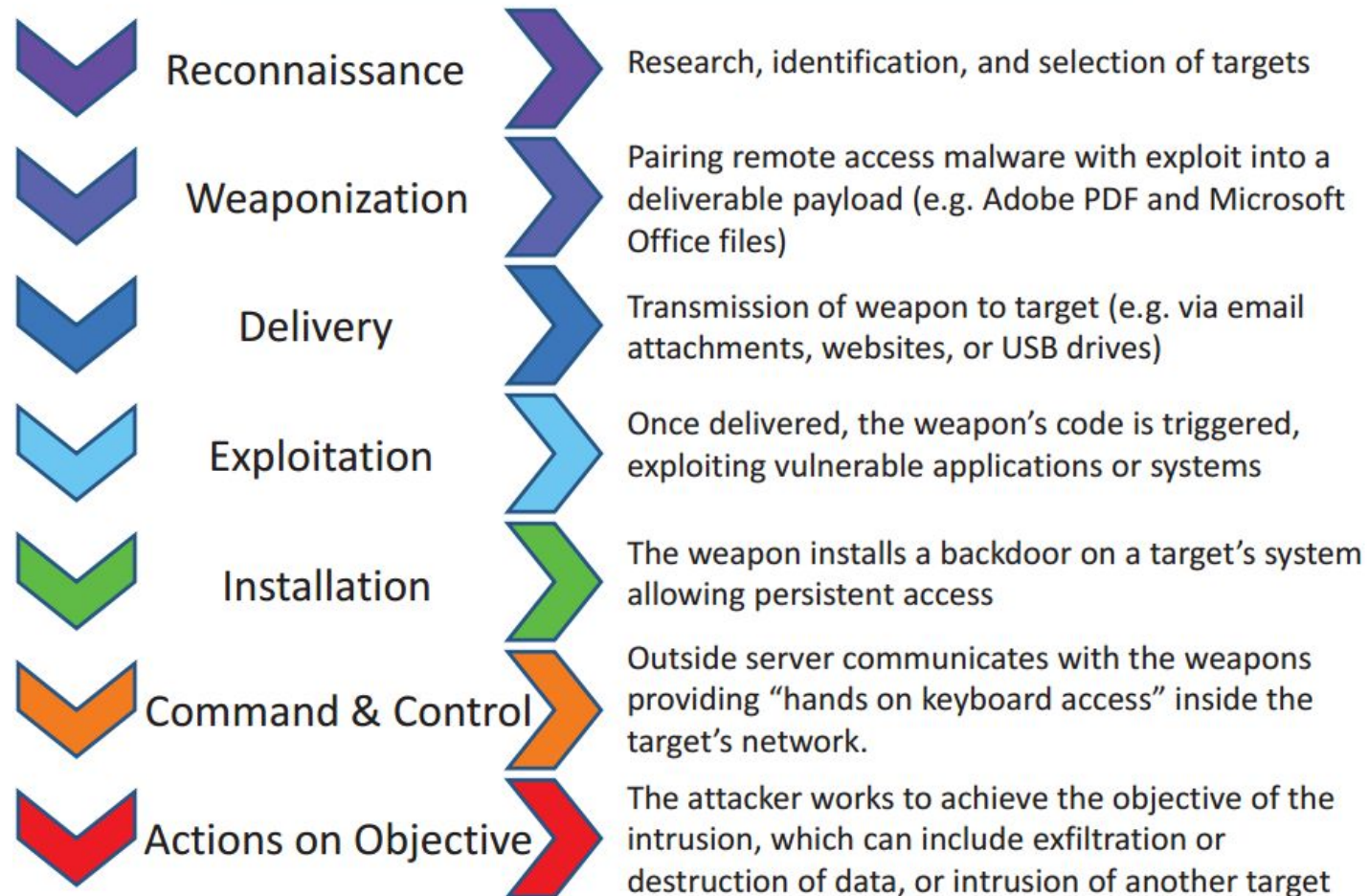
With hands on access the attacker and achieve their objective.



CYBER KILL CHAIN



Phases of the Intrusion Kill Chain



CYBER KILL CHAIN



1. Reconnaissance

Reconnaissance is the first stage of the Cyber Kill Chain model. It provides insights about potential targets and studies them. You also learn about their vulnerabilities and find out which third parties these targets may be connected to. You will also explore other potential entry points, find new ones, and reconnaissance can happen both online and offline as well.

2. Weaponization

Cyber weapons and kill chain tools will be used to attack and penetrate the target's network. These tools can range from malware, ransomware strains, payloads, and other malicious variants.

CYBER KILL CHAIN



3. Delivery

The adversaries will try to reach users and send a wide variety of phishing means that contain malicious links. The subject lines in these emails will try to coax or prompt the victim into taking action. After delivery is successful, the adversary can hack into the organization's network and exploit hardware and software vulnerabilities further.

4. Exploitation

Attackers will try to penetrate networks deeper and take advantage of the vulnerabilities that they discovered and exploited in the previous steps. They will try to advance in their objectives and attempt to move laterally across networks to reach bigger targets. If any targets are responsible for the network and have not deployed necessary security measures, then attackers will go after them.

CYBER KILL CHAIN



5. Installation

The installation phase involves attempting to install malware and other ransomware variants on the target networks. The attackers will try to take control over your systems and exfiltrate sensitive data. They may also install other cyberweapons, trojan horses, backdoors, and command-line interfaces.

6. Command-and-Control (C2)

In the command-and-control phase of the cyberkill chain, attackers will try to communicate with the malware they've just planted onto your networks. They will instruct the tools to carry out specific tasks remotely. The attackers will use communication channels to control computers that have been infected with their malware and botnets. They can try to overload websites with traffic or instruct C2 servers to carry out their mission.

CYBER KILL CHAIN



7. Actions on Goals

This is the final stage where attackers will try to carry out their objectives and succeed in them. Their goals can vary depending on the type of cyber attack that they are launching. Some attackers will try to interrupt your services, take them down or make the organization go completely online. They might distribute malware to steal sensitive data, launch denial of service attacks, or use ransomware as a means of extorting the organization.

THREAT



- A threat is any entity, event or condition capable of causing damage to information systems, networks, applications or digital assets. A threat represents the potential source of harm, whether intentional or accidental. Common Types of Threats:
- **Malware Threats:** Software intentionally designed to disrupt operations, steal information or gain unauthorized access. Examples Ransomware, Trojan horses, Worms, Spyware, Rootkits.
- **Network-Based Threats:** Threats targeting communication channels and network services. Examples Distributed Denial-of-Service (DDoS), ARP spoofing, DNS poisoning, Packet sniffing, Session hijacking.
- **Insider Threats:** Individuals with authorized access who intentionally or unintentionally compromise security. Examples Privilege misuse, Data leakage, Credential sharing, Unauthorized configuration.
- **Physical Threats:** Events affecting hardware infrastructure. Examples Device theft, Fire, Flood, Power failure, Hardware sabotage.

VULNERABILITY



A vulnerability is a weakness in software, hardware, network infrastructure, operating systems or security processes that could allow unauthorized actions when exposed to a threat. Common Sources of Vulnerabilities:

- **Software Vulnerabilities:** Buffer overflow, SQL injection, Cross-Site Scripting (XSS), Remote code execution flaws, Integer overflow.
- **Configuration Vulnerabilities:** Default credentials, Open administrative ports, Weak password policies, Improper firewall rules, Unrestricted file permissions.
- **Operating System Vulnerabilities:** Missing security updates, Unsupported operating systems, Insecure services, Kernel flaws.
- **Network Vulnerabilities:** Unencrypted protocols, Weak wireless encryption, Misconfigured routers, Exposed management interfaces.

RISK



- Risk is the possibility that a threat will successfully exploit a vulnerability and produce a negative impact on business operations, data or infrastructure. it measures the likelihood of exploitation combined with the potential consequences. Risk Categories:
- **Low Risk:** Difficult to exploit, Minimal operational impact, Strong mitigating controls.
- **Medium Risk:** Exploitable under certain conditions, Moderate business disruption, Limited data exposure.
- **High Risk:** Easily exploitable, Significant operational impact, Sensitive information at risk.
- **Critical Risk:** Publicly accessible attack surface, Reliable exploitation methods available, Severe financial, operational or reputational consequences.

RISK



A common risk assessment model is

- **Likelihood** estimates the probability of successful exploitation.
- **Impact** measures the resulting damage if exploitation occurs.
- *$Risk = Likelihood \times Impact$*

THREAT ACTORS



- Threat actors, also known as cyberthreat actors or malicious actors, are individuals or groups that intentionally cause harm to digital devices or systems. Threat actors exploit vulnerabilities in computer systems, networks and software to perpetuate various cyberattacks, including phishing, ransomware and malware attacks.
- Today, there are many types of threat actors, all with varying attributes, motivations, skill levels and tactics. Some of the most common types of threat actors include hacktivists, nation-state actors, cybercriminals, thrill seekers, insider threat actors and cyberterrorists.

TYPES OF THREAT ACTORS



1. Cybercriminals:

- These individuals or groups commit cybercrimes mostly for financial gain. Common crimes that are committed by cybercriminals include ransomware attacks and phishing scams that trick people into making money transfers or divulging credit card information, login credentials, intellectual property or other private or sensitive information.

2. Nation-state actors:

- Nation states and governments frequently fund threat actors with the goal of stealing sensitive data, gathering confidential information or disrupting another government's critical infrastructure. These malicious activities often include espionage or cyberwarfare and tend to be highly funded, making the threats complex and challenging to detect.

TYPES OF THREAT ACTORS



3. Hacktivists:

- These threat actors use hacking techniques to promote political or social agendas, such as spreading free speech or uncovering human rights violations. Hacktivists believe that they are affecting positive social change and feel justified in targeting individuals, organizations or government agencies to expose secrets or other sensitive information. A well-known example of a hacktivist group is Anonymous, an international hacking collective that claims to advocate for freedom of speech on the internet.

4. Thrill seekers:

- Thrill seekers are just what they sound like: they attack computer and information systems primarily for fun. Some want to see how much sensitive information or data they can steal. Others want to use hacking to better understand how networks and computer systems work. One class of thrill seekers, called script kiddies, lack advanced technical skills, but use preexisting tools and techniques to attack vulnerable systems, primarily for amusement or personal satisfaction. Though they don't always seek to cause harm, thrill seekers can still cause unintended damage by interfering with a network's cybersecurity and opening the door to future cyberattacks.

TYPES OF THREAT ACTORS



5. Insider threats:

- Unlike most other actor types, insider threat actors do not always have malicious intent. Some hurt their companies through human error, such as by unwittingly installing malware or losing a company-issued device that a cybercriminal finds and uses to access the network. But malicious insiders do exist. For example, the disgruntled employee who abuses access privileges to steal data for monetary gain or inflicts damage to data or applications in retaliation for being passed over for promotion.

6. Cyberterrorists:

- Cyberterrorists start politically or ideologically motivated cyberattacks that threaten or result in violence. Some cyberterrorists are nation-state actors; others are actors on their own or on behalf of a nongovernment group.

ATTACK SURFACE



- The attack surface is the number of all possible points, or attack vectors, where an unauthorized user can access a system and extract data. The smaller the attack surface, the easier it is to protect.
- Organizations must constantly monitor their attack surface to identify and block potential threats as quickly as possible. They also must try and minimize the attack surface area to reduce the risk of cyberattacks succeeding. However, doing so becomes difficult as they expand their digital footprint and embrace new technologies.
- The attack surface is split into two categories: the digital and physical.

ATTACK SURFACE



1. Digital attack surface:

The digital attack surface area encompasses all the hardware and software that connect to an organization's network. These include applications, code, ports, servers, and websites, as well as shadow IT, which sees users bypass IT to use unauthorized applications or devices.

ATTACK SURFACE



2. Physical Attack Surface:

The physical attack surface comprises all endpoint devices that an attacker can gain physical access to, such as desktop computers, hard drives, laptops, mobile phones, and universal serial bus (USB) drives. The physical attack threat surface includes carelessly discarded hardware that contains user data and login credentials, users writing passwords on paper, and physical break-ins.

Organizations can protect the physical attack surface with support from a managed security service provider (MSSP), which may include implementing access control, surveillance, and physical security policies. They also must implement and test disaster recovery procedures and policies.

INFORMATION SECURITY PRINCIPLES



1. Defence in Depth:

Defence in Depth is a security strategy that uses **multiple layers of security controls** so that if one control fails, others continue to protect the system.

Key Points:

- Prevents a single point of failure.
- Combines physical, technical, and administrative controls.
- Improves the overall resilience of an organization.

INFORMATION SECURITY PRINCIPLES



Examples:

- Firewall → Intrusion Detection System (IDS) → Antivirus → Multi-Factor Authentication (MFA).
- Security guard → Biometric access → CCTV surveillance for a data center.

Benefits:

- Reduces the risk of successful cyberattacks.
- Provides multiple opportunities to detect and stop attackers.

INFORMATION SECURITY PRINCIPLES



2. Least Privilege:

The Principle of Least Privilege (PoLP) states that **users, applications, and systems should only have the minimum permissions necessary** to perform their tasks.

Key Points:

- Limits unnecessary access.
- Reduces the impact of compromised accounts.
- Prevents accidental or intentional misuse of data.

INFORMATION SECURITY PRINCIPLES



Examples:

- A student can only view their own grades.
- An HR employee cannot access financial records.
- A software application has only read access instead of full administrator privileges.

Benefits:

- Minimizes insider threats.
- Reduces the attack surface.
- Improves accountability.

INFORMATION SECURITY PRINCIPLES



3. Separation of Duties:

Separation of Duties means **dividing critical tasks among multiple individuals** so that no single person has complete control over an important process.

Key Points:

- Prevents fraud and abuse.
- Ensures checks and balances.
- Reduces the possibility of errors.

INFORMATION SECURITY PRINCIPLES



Examples:

- One employee creates a payment request, while another approves it.
- A developer writes code, but a different team reviews and deploys it.
- One administrator creates user accounts, while another assigns privileges.

Benefits:

- Increases accountability.
- Detects mistakes more easily.
- Reduces insider threats.

INFORMATION SECURITY PRINCIPLES



4. Need to Know:

The Need-to-Know principle states that **information should only be accessible to individuals who require it to perform their job responsibilities**, even if they already have the necessary security clearance.

Key Points:

- Restricts access to sensitive information.
- Protects confidential and classified data.
- Works alongside the Least Privilege principle.

INFORMATION SECURITY PRINCIPLES



Examples:

- A doctor can access only the records of patients under their care.
- Employees in the finance department cannot access confidential R&D documents.
- A project team can view only documents related to their project.

Benefits:

- Prevents unauthorized information disclosure.
- Improves confidentiality.
- Reduces the risk of data leakage.

INFORMATION SECURITY PRINCIPLES



5. Fail – Safe Defaults:

Fail-Safe Defaults means that **access should be denied by default**, and permissions are granted only when explicitly authorized. If a system fails, it should remain in a secure state.

Key Points:

- Uses a **default deny** approach.
- Prevents accidental access during failures.
- Ensures security even when errors occur.

INFORMATION SECURITY PRINCIPLES



Examples:

- A firewall blocks all incoming traffic unless a rule specifically allows it.
- A newly created user account has no permissions until access is assigned.
- If an authentication server is unavailable, users are denied access instead of being automatically logged in.

Benefits:

- Reduces unauthorized access.
- Improves system security.
- Prevents privilege escalation due to configuration errors.

ANY QUERIES??



Contact
gayathri.g@techdefence.com



